UNIVERSIDAD COMPLUTENSE MADRID

ntic master

DOCUMENTACIÓN

Máster en Ciberseguridad

MÓDULO

Detección, Correlación y Acción

PROFESOR

D. Javier Corbalán Colino

ÍNDICE

1. Tarea evaluable Detección, Correlación y Acción 3
1.1. Introducción 3
1.2. Trabajo con ficheros STIX 4
1.3. Normalización de eventos 5
1.4. Búsquedas en Splunk 7
1.5. Cómo entregar la tarea 8

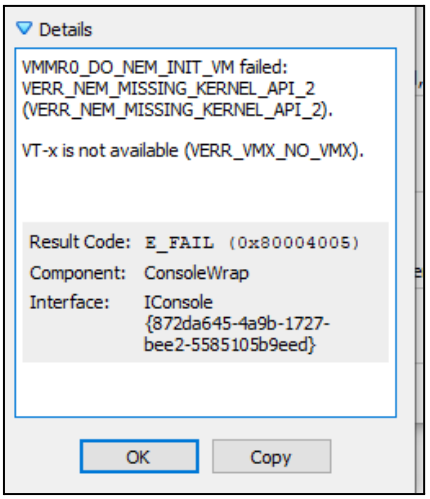
1. Tarea evaluable Detección, Correlación y Acción

1.1. Introducción

Deberás realizar estas tareas evaluables que, en conjunto, representarán tu nota final del módulo. Para ello, deberás hacer uso de los materiales provistos y seguir las instrucciones de los enunciados.

Para poder ejecutar la máquina virtual (necesaria para el ejercicio 1.4), se debe descargar e instalar Oracle Virtualbox: https://www.virtualbox.org/ y el correspondiente fichero ovf del campus virtual. La máquina debe de ser importada a VirtualBox y se puede utilizar con normalidad. La máquina virtual provista está configurada con 8GB de RAM y 2 núcleos para que Splunk funcione correctamente, aunque con 4 núcleos funcionará mejor.

Si al arrancar la máquina virtual aparece el error "VT-x/AMD-V is not available", debes asegurarte de que tienes activado en tu BIOS las extensiones de virtualización de tu CPU.



Las credenciales del único usuario administrador son siemadmin:SIEMADM1N, indicadas también en la descripción de la máquina.

Si observas parpadeo en la pantalla de la máquina virtual, apágala, asegúrate de que seleccionas el driver de pantalla VMSVGA y habilita la aceleración 3D.

Una vez encendida la máquina, para arrancar Splunk se debe abrir un terminal, elevar privilegios y ejecutar el comando de arranque:

```
siemadmin@vbox:~$ su -
Contraseña:
root@vbox:~# /opt/splunk/bin/splunk start
```

Una vez Splunk indique que está disponible en vbox:8000, puedes cerrar la consola y abrir Firefox donde podrás iniciar sesión con las mismas credenciales. Este usuario también es administrador del SIEM.

Los CSVs necesarios para las demostraciones prácticas y la tarea están en el fichero

comprimido “material-tarea-evaluable-y-demos-practicas.zip”.

1.2. Trabajo con ficheros STIX

Valor: +2 puntos

Analiza este fichero STIX 2.1 (STIX.json) con la herramienta que desees (puedes utilizar https://oasis-open.github.io/cti-stix-visualization/) y contesta a las siguientes preguntas:

- ¿Quién es el autor del informe?
- ¿De qué adversario trata el informe?
- ¿Cómo clasificarías a este adversario dentro de los seis tipos que hemos visto?
- ¿En qué año se identificó por primera vez actividad de este adversario?
- ¿Está relacionado con algún otro adversario conocido?
- ¿Qué vulnerabilidades suele explotar este adversario? (CVE y explicación breve del producto afectado y la vulnerabilidad)
- ¿Qué 5 direcciones de e-mail aparecen como indicadores?
- ¿Qué finalidad crees que cumplen estas direcciones de e-mail para el adversario y sus víctimas?
- ¿Qué técnicas descritas en la matriz de MITRE ATT&CK utiliza el adversario para el comando y control (TA0011 - Command and Control)? (Código identificador y nombre de la técnica / subtécnica)
- Entre las herramientas utilizadas por el adversario se encuentran Mimikatz, Anydesk y Certutil. Para cada una de ellas, contesta a las siguientes preguntas:
    - ¿Se encuentra por defecto en Windows?
    - ¿La categorizarías como malware?
    - Si no la categorizarías como malware, ¿por qué aparece el informe?

1.3. Normalización de eventos

Valor: +3.5 puntos

Usando esta traza (payload.txt) de un payload syslog proveniente de un firewall Palo Alto Networks:

```
<180>May  6 16:43:53 paloalto.evil.corp LEEF:1.0|Palo Alto
Networks|PAN-OS Syslog
Integration|8.1.6|trojan/PDF.gen.eiez(268198686)|ReceiveTime=2025/05/06
16:43:53|SerialNumber=001801010877|cat=THREAT|Subtype=virus|devTime=May
06 2025 16:43:53
GMT|src=10.2.75.41|dst=192.168.178.180|srcPostNAT=192.168.68.141|dstPostN
AT=192.168.178.180|RuleName=Test-1|usrName=ealderson|SourceUser=ealderson
|DestinationUser=|Application=web-browsing|VirtualSystem=vsys1|SourceZone
=INSIDE-ZN|DestinationZone=OUTSIDE-ZN|IngressInterface=ethernet1/1|Egress
Interface=ethernet1/3|LogForwardingProfile=testForwarder|SessionID=3012|R
epeatCount=1|srcPort=63508|dstPort=80|srcPostNATPort=31539|dstPostNATPort
=80|Flags=0x406000|proto=tcp|action=alert|Miscellaneous="badguys.co/du/up
loads/08052018_UG_FAQ.pdf"|ThreatID=trojan/PDF.gen.eiez(268198686)|URLCat
egory=educational-institutions|sev=3|Severity=medium|Direction=server-to-
client|sequence=486021038|ActionFlags=0xa000000000000000|SourceLocation=1
0.0.0.0-10.255.255.255|DestinationLocation=testPlace|ContentType=|PCAP_ID
=0|FileDigest=|Cloud=|URLIndex=5|RequestMethod=|Subject=|DeviceGroupHiera
rchyL1=12|DeviceGroupHierarchyL2=0|DeviceGroupHierarchyL3=0|DeviceGroupHi
erarchyL4=0|vSrcName=|DeviceName=testName|SrcUUID=|DstUUID=|TunnelID=0|Mo
nitorTag=|ParentSessionID=0|ParentStartTime=|TunnelType=N/A|ThreatCategor
y=pdf|ContentVer=Antivirus-2969-3479
```

- ¿Cúal es el nombre de equipo (FQDN) del propio firewall del que proviene la traza syslog?

Indica expresiones regulares y grupos de captura para extraer los siguientes atributos:

Atributo	**Valor**	**Expresión regular**	**Grupo de captura**
Categoría	THREAT		
Subtipo	virus		
Timestamp	May 06 2025 16:43:53 GMT		
IP origen	10.2.75.41		

IP destino	192.168.178.180		
Regla	Test-1		
Usuario	ealderson		
Aplicación	web-browsing		
Sistema Virtual	vsys1		
Zona Origen	INSIDE-ZN		
Zona Destino	OUTSIDE-ZN		
Puerto Origen	63508		
Puerto Destino	80		
Protocolo	tcp		
URL	badguys.co/du/uploads/08052018_UG_FAQ.pdf		
Categoría URL	educational-institutions		
Dominio	badguys.co		
Nombre Fichero	08052018_UG_FAQ.pdf		
Firma	trojan/PDF.gen.eiez		
ID firma	268198686		

1.4. Búsquedas en Splunk

Valor: +4.5 puntos

Con la máquina virtual provista y en base al dataset **(index=botsv1, especificando el rango "All Time" salvo que en la consulta se especifique lo contrario)**, dar respuesta a las siguientes preguntas indicando la consulta SPL correspondiente y los resultados. **Es muy importante verificar que el rango temporal está configurado a "All Time" antes de cada búsqueda** puesto que puede resetearse a últimas 24 horas si se cambia de vista en Splunk:

- ¿Cuántos eventos hay en el índice "botsv1"?

- ¿Cuáles son los tres "sourcetype" con más eventos por sourcetype en el índice "botsv1"?

- ¿Cuántos eventos contienen la palabra "ellyn.baltimore"?

- ¿Cuáles son los tres servidores (host) que más eventos han generado que contengan la palabra "ellyn.baltimore"?

- ¿Según la auditoría de seguridad de Windows, cuáles han sido los 4 programas ejecutados más veces por Bree.Moser (source="wineventlog:security" EventCode=4688 user=Bree.Moser) durante el 12/08/2016?

- ¿Cuáles han sido los 5 sitios (site) externos (dest_ip pública) más visitados (sourcetype="stream:http")?

- ¿Qué endpoints (host) ordenados por número descendiente de conexiones tienen más de 640 conexiones de red registradas por sus agentes de Sysmon? (sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational" EventCode=3)

- ¿Cuáles han sido los 8 nombres de ejecutables (process) que han originado procesos más anómalos en el equipo "we8105desk" según los eventos de Sysmon? La respuesta debe incluir los nombres de cada ejecutable en MAYÚSCULAS, su recuento y el porcentaje que representa del total. (sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational" EventCode=1 host=we8105desk)

- El equipo de sistemas observa actividad extraña en los servidores web y sospechas que alguien haya intentado explotar una vulnerabilidad de Path Traversal conocida por el equipo de desarrollo pero que aún no habían resuelto. Para contestar con certeza, revisas el tráfico http (sourcetype="stream:http") del que dispones en Splunk y sabes que un signo evidente de intento de explotación de estar vulnerabilidades es la presencia de ".." (dos puntos seguidos) en la URL (uri) de una solicitud HTTP. ¿Puedes determinar si alguna IP ha realizado solicitudes que puedan indicar que estaba intentando explotar esta vulnerabilidad y en qué país está o están ubicadas?

- ¿Puedes confirmar si hay algún tipo de comunicación HTTP (sourcetype=”stream:http”) hacia IPs públicas hacia algún puerto (dest_port) poco común (diferente al 80)? En caso afirmativo, ¿cuál es la IP (dest_ip) y el dominio (site)?

- El equipo de sistemas te avisa de comportamiento sospechoso en el equipo “we1149srv” (host) y te pide confirmar si se ha ejecutado (EventCode=1) algún programa (app) malicioso en los eventos de Sysmon (sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational"). Como primera aproximación, decides cargar tu listado de hashes SHA256 de malware conocido (malicious-executable-hashes.csv) como lookup table para determinar si el hash (SHA256) de algún proceso lanzado coincide con los del listado. En caso de que alguno coincida, indica la descripción que ofrece el indicador y describe brevemente de qué tipo de malware se trata.

- Entre el tráfico HTTP (sourcetype="stream:http") saliente hacia IPs públicas (dest_ip no privada), determina cuántas solicitudes HTTP se han realizado al TLD de cada dominio (site). Es decir, si el site=”whatever.microsoft.com”, el TLD de ese dominio será “com”. Ordena los resultados de TLD con más solicitudes a TLD con menos solicitudes.

1.5. Cómo entregar la tarea

El alumno debe elaborar un guión de la tarea que contenga:

- Las preguntas de la tarea 1.2 y sus respectivas respuestas.
- La tabla de la tarea 1.3 debidamente rellenada con sus expresiones regulares y grupos de captura definidos (con número o nombre).
- Las preguntas y respuestas de la tarea 1.4 con sus SPLs y explicaciones correspondientes cuando procedan.

El alumno debe subir su guión en un archivo PDF con el siguiente patrón en el nombre del archivo:

TAREA_DNI_NOMBRE_APELLIDO1_APELLIDO2.pdf

Cualquier duda o incidencia con la entrega se puede consultar directamente con el profesor a través del foro y chat del Campus de la Universidad.